Team SSO and Team dashboard: OWASP Top 10 baseline review, 5 Nov 2026 (IST)

Scope: branch `feat/team-sso` (team server OIDC sign-in, the `seen team` CLI login, the dashboard sign-in and the Team page proxy), reviewed at `c771b7c` and re-checked after the fixes in the two `Security fixes` commits.

Method: manual code review against the OWASP Top 10 baseline (A01 to A10), two read-only probes, and a live check of a real team server, CLI and dashboard against a fake IdP. The `cso --owasp` skill was not run.

This report holds no secrets, tenant ids or personal data. Test addresses use reserved domains.

Summary

Severity	Found	Fixed	Accepted	Open
Critical	0	0	0	0
High	0	0	0	0
Medium	1	1	0	0
Low	4	4	0	0
Info	3	2	0	1
Unconfirmed (confidence below 8)	5	2	2	1

Nothing was remotely exploitable without a precondition. Decision items for the owner (below) remain open.

Findings and status

ID	Severity	Finding	Status	Resolution
SSO-A1	Medium	The Docker snapshot dashboard was team-configured and could mint a live SSO key into the host snapshot folder	Fixed	`seen docker-sync` strips the `[sync]` table (an unparsable config is not copied); a dashboard started with `--allow-remote` or a non-loopback bind returns `not_configured` for session, projects, overview and members without any outbound call, returns no login URL, only redirects on the callback, and ignores logout. Mounting `/snap` read-only in the compose file is recommended and not yet done
SSO-A2	Low	The ASCII guard against case-folding (Kelvin sign) was bypassed because `_domain_ok` lowercased first	Fixed	`_domain_ok` rejects any non-ASCII address before lowercasing; the test goes through the real validator
SSO-A3	Low	An id_token could be replayed to mint many 30-day keys	Fixed	`sha256(id_token)` is stored in `team_used_tokens` until `exp` plus leeway; a replay gets the fixed 401 and counts as a failure for the limiter; concurrent double submit mints one key
SSO-A4	Low	`SEEN_TEAM_PROXY_HOPS` undocumented; a bad value turned every request into a 500; limiter tables grew without bound	Fixed	Parsed once at startup (bad value stops the server with a fixed error); documented in ADR 0018; idle addresses are dropped and the tables are capped at 10,000 entries
SSO-A5	Low	Deactivating an SSO user did not stop manual keys bound to the same user id	Fixed	Deactivate and erase revoke every live key with that `user_id`, whatever its origin; reactivation does not restore them
SSO-A6	Info	Team server 500 responses carry no security headers	Open	Not changed in this round; the API is JSON only and the body has no detail
SSO-A7	Info	Test fixtures used the company's real e-mail domain	Fixed	Replaced with `example.com` and `example.org` in tests and docs
SSO-A8	Info	The ADR pip-audit note mixed dev and production dependencies	Fixed	ADR 0018 now states that the certifi advisory is in dev and test only
U1	Medium (confidence 6)	Bootstrap admin matches the changeable Entra `email` claim	Open	Recorded as ADR 0018 open decision 8; recommend matching admins by IdP object id after first login, or rejecting guests and unverified domains; verify against a real tenant first
U2	Low	Non-Entra issuers accept a missing `email_verified` without a tenant pin	Accepted	Documented as a known limit
U3	Info	A plain-http loopback issuer was accepted with `APP_ENV=production`	Fixed	Production refuses to start with a non-https issuer

ID	Severity	Finding	Status	Resolution
U4	Low	CLI and dashboard login calls honoured proxy variables and read replies without a cap	Fixed	The opener ignores proxies and replies are capped at 1 MB (over the cap is a failure)
U5	Low	IPv6 clients can rotate source addresses to refresh the throttle budget	Accepted	Documented; keys carry 256 bits, so this weakens the limiter, not the keys

Decision items for the owner (open)

- **Plaintext e-mail at rest (DPDP).** `TeamUser.email` is stored in plaintext and nothing in `deploy/` configures volume encryption or encrypted backups. It is an open finding until the owner picks database or volume encryption plus encrypted backups, or field-level encryption. The pseudonymous `sub` kept after an erase needs the owner's sign-off on its purpose.
- **Project scoping.** An SSO member can push changes under any project id, and an SSO lead sees every project's member e-mails.
- **Bootstrap key in production.** The static admin key never expires and coexists with SSO unless `SEEN_TEAM_BOOTSTRAP_DISABLE` is set.
- **Manual-key installs after SSO login** get a 403 on the same install id until an admin re-binds them (an availability gap, not a vulnerability).
- **Bootstrap admin by e-mail claim** (U1 above).

Checked and found clean

- **A02, A07 secrets:** production refuses a short bootstrap key and a bootstrap-disabled install with no OIDC; keys are 256-bit, stored as SHA-256, shown once and never logged or placed in URLs; the CLI key file is mode 0600.
- **A07 throttling:** a per-IP limiter counts successes and failures, a locked address gets 429 even with a correct key, and there is no per-account lockout.
- **A05 headers:** the team server sends `X-Frame-Options: DENY`, a CSP with `frame-ancestors 'none'`, `nosniff`, `Referrer-Policy` and `Permissions-Policy`, hides the server header and disables API docs in production. HSTS belongs at the TLS terminator.
- **A05 containers:** the team image runs as a non-root user.
- **A06, A08 supply chain:** `pyjwt` is pinned exactly; lockfiles are tracked; images use frozen installs and `npm ci`; `pip-audit` on the production export finds nothing and `npm audit --omit=dev` finds 0. The one advisory in `uv.lock` (certifi) is in the dev and test dependencies only.
- **JWT validation:** RS256 only, exact issuer and audience, required claims, Entra tenant id pin, constant-time nonce compare, JWKS over https with a size cap and bounded refresh, fixed error strings.
- **PKCE, state and CSRF:** S256 with a 32-byte verifier; random state and nonce; one-shot loopback listener; single-use, capped pending store; the dashboard login and logout need `X-Seen-Request` and the host check blocks DNS rebinding.
- **Open redirect:** the callback always answers 303 to the fixed path `/team`.
- **SSRF and path injection:** the proxy URL comes only from the local config; no redirects, no environment proxy, 2 MB cap; the project id is validated and quoted.
- **XSS:** the Team page renders server values as React text and validates proxy bodies against typed schemas.
- **A01 access control:** user and key routes are admin only, roles are re-read on every SSO request, and erase revokes all keys.
- **Logging:** the callback query is not access-logged; errors carry fixed text; audit events hold outcomes only.
- **Live check (fake IdP, SQLite, real processes):** 34 checks passed, 0 failed; no key or token appeared in any response, log or database.

Not verified

- A **live Entra tenant**: real token claims (`email`, `acct`, `xms_edov`), guest behaviour and redirect URI matching. Only a fake IdP was used.
- The **Postgres and Docker compose stack**: response headers, the container user and throttle codes were not reproduced live, so the baseline step "reproduce on the live Docker stack" is still open.
- A **real-browser CSP check** of the Team page with a `securitypolicyviolation` listener.
- **Concurrency**: the last-admin guard race and the first-login insert race were reviewed by reading only; the one-time id_token rule has a two-thread test on SQLite, not on Postgres.
- The expiry of a pending dashboard login (10 minutes) is covered by unit tests only.